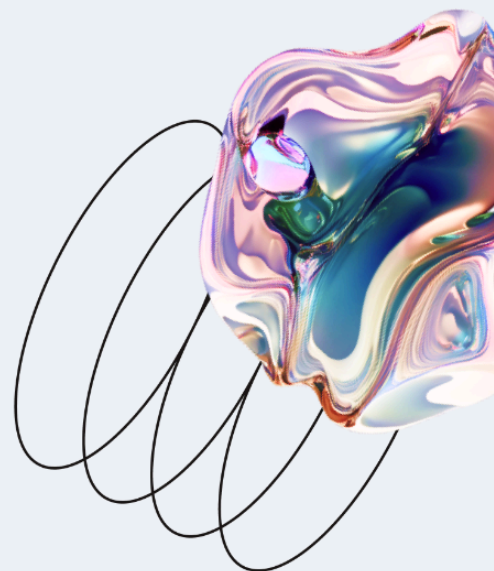




Основные технологии и инструменты обеспечения ИБ

Основы информационной
безопасности



Оглавление

Введение.....	4
Словарь терминов.....	4
Эволюция технологий и инструментов обеспечения ИБ.....	5
Система сертификации средств защиты информации.....	7
Встроенные и наложенные средства защиты информации.....	11
Идентификация.....	11
Аутентификация.....	12
Пароли.....	13
Популярные парольные атаки.....	14
Современные протоколы аутентификация.....	15
Авторизация.....	17
Мандатное разграничение прав доступа.....	17
Дискреционное разграничение прав доступа.....	18
Ролевое разграничение прав доступа.....	19
Регистрация (учёт) событий безопасности.....	19
Средство антивирусной защиты.....	20
Сигнатурный анализ.....	20
Эвристический анализ.....	21
Поведенческий анализ.....	21
Наложенные СрЗИ от несанкционированного доступа.....	21
Хостовые и сетевые средства защиты информации.....	22
Межсетевые экраны.....	23

Система обнаружения/предотвращения вторжений.....	25
Средства управления ИБ.....	26
Интеграции и экосистемы средств защиты информации.....	26
Выводы.....	27
Дополнительные материалы.....	27
Использованная литература.....	28

Введение

Сегодня мы продолжим курс, посвящённый основам обеспечения информационной безопасности (ИБ), а текущее занятие – основные технологии и инструменты обеспечения ИБ (некриптографические).

На этой лекции вы узнаете:

- Как проходила эволюция технологий и инструментов обеспечения ИБ?
- Какие есть классы средств защиты информации (СрЗИ)?
- Зачем нужна система сертификации СрЗИ?
- Чем отличаются встроенные и наложенные СрЗИ?
- Для чего нужны хостовые и сетевые СрЗИ?
- Зачем нужны средства управления ИБ?
- Что дают интеграции и экосистемы СрЗИ?

Словарь терминов

Средство защиты информации – техническое, программное, программно-техническое средство, вещество и/или материал, предназначенные или используемые для защиты информации ([ГОСТ Р 50922-2006](#)).

Техническое средство обеспечения информационной безопасности – оборудование, используемое для обеспечения информационной безопасности организации некриптографическими методами ([ГОСТ Р 53114-2008](#)).

Криптографическое средство защиты информации – средство защиты информации, реализующее алгоритмы криптографического преобразования информации ([ГОСТ Р 50922-2006](#)).

Сертификация на соответствие требованиям по безопасности информации – форма оценки соответствия требованиям по безопасности информации, установленным нормативными правовыми актами ФСТЭК России, а также техническими условиями, техническим заданием, заданием по безопасности, согласованными заявителями на сертификацию с ФСТЭК России (требования по безопасности информации), адаптировано из [«Положения о системе сертификации средств защиты информации», утв. приказом ФСТЭК России от 03.04.2018 N 55](#).

Идентификация – действия по присвоению субъектам и объектам доступа идентификаторов и/или по сравнению предъявляемого идентификатора с перечнем присвоенных идентификаторов ([ГОСТ Р 58833-2020](#)).

Аутентификация – действия по проверке подлинности субъекта доступа и/или объекта доступа, а также, по проверке принадлежности субъекту доступа и/или объекту доступа предъявленного идентификатора доступа и аутентификационной информации ([ГОСТ Р 58833-2020](#)).

Пароль – конфиденциальная аутентификационная информация, обычно состоящая из строки знаков ([ГОСТ Р 58833-2020](#)).

Мнемонический пароль – пароль, образованный от простых слов (фраз), которые пользователь сможет легко запомнить (используя их первые буквы и/или слоги) и мнемонические замены (например, букву “О” на цифру “0”).

Доступ – получение одной стороной информационного взаимодействия возможности использования ресурсов другой стороны информационного взаимодействия ([ГОСТ Р 58833-2020](#)).

Санкционированный доступ – доступ субъекта доступа к объекту доступа, не нарушающий правила управления доступом ([ГОСТ Р 58833-2020](#)).

Несанкционированный доступ – доступ субъекта доступа к объекту доступа, нарушающий правила управления доступом ([ГОСТ Р 58833-2020](#)).

Авторизация – предоставление субъекту доступа прав доступа, а также предоставление доступа в соответствии с установленными правилами управления доступом ([ГОСТ Р 58833-2020](#)).

Событие безопасности – идентифицированное состояние системы или её отдельных компонентов, которое значимо для информационной безопасности, и зарегистрированная информация об этом состоянии (адаптировано из [ГОСТ Р 59548-2022](#)).

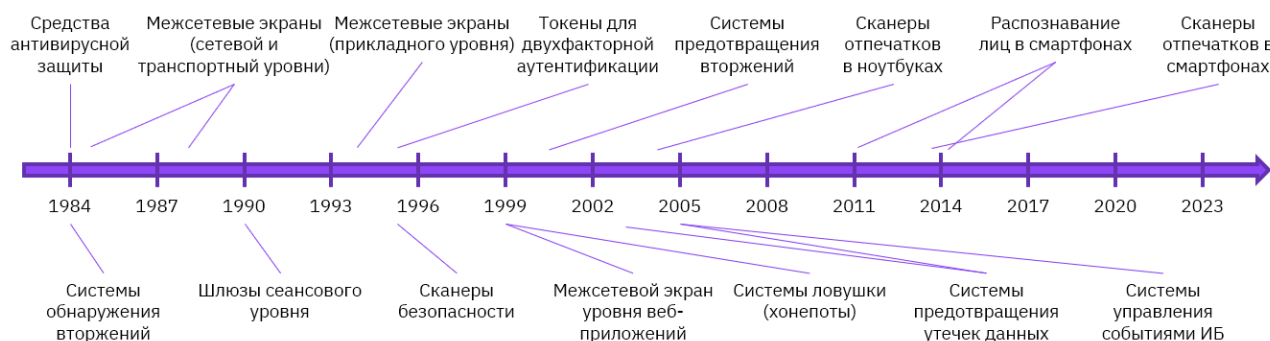
Регистрация событий безопасности – процесс автоматического (автоматизированного) внесения в электронный журнал регистрации событий безопасности записи о событии безопасности ([ГОСТ Р 59548-2022](#)).

Эволюция технологий и инструментов обеспечения ИБ

Стоит начать с того, что защита некриптографическими методами изначально базировалась на средствах разграничения прав доступа, которые существовали достаточно давно. Любой самый простой дверной замок и ключи к нему – это механическая реализация разграничения прав доступа. Есть ключ – есть доступ, нет ключа – нет доступа.

Но в части эволюции именно технологий и инструментов обеспечения ИБ рассмотрим появление различных целевых решений по защите информации в информационных системах и сетях, считая, что разграничение прав доступа в каком-то виде уже есть.

История развития средств защиты информации



Стартовала данная тематика с направлений антивирусной защиты и обнаружения вторжений в 1984 году и развивается до сих пор. Сейчас акценты делаются на управление разрозненными техническими средствами обеспечения ИБ и построение экосистем ИБ.

В мировой динамике ежегодно можно смотреть, как меняется расположение технологий ИБ (классов CpЗИ) на кривых *Gartner Hype Cycle*, проходя последовательно пять фаз развития:

- **инновационный триггер:** фаза запуска, когда новая технология «выходит в свет»
- **пик завышенных ожиданий:** фаза ажиотажа, когда повышенный интерес провоцируют появление иллюзий и завышенных ожиданий от технологии

- **пропасть разочарования:** фаза угасания интереса, когда обнаруживаются недостатки и ограничения технологии (на данном этапе многие технологии, так и не «оправившись», преждевременно завершают свой жизненный цикл)
- **склон просветления:** фаза реабилитации, когда исправляются ошибки и возникают новые решения
- **плато продуктивности:** фаза применения технологии на рынке (достижение зрелости)

Классы средств защиты информации

Средства защиты информации условно можно разделить на следующие классы:

- по области применения/инсталляции:
 - хостовые
 - сетевые
- по изначальной принадлежности к информационной системе (приложению):
 - встроенные
 - наложенные
- по используемым механизмам защиты:
 - некриптографические (СрЗИ)
 - криптографические (СКЗИ)
- по возможностям противодействия атакующему:
 - активные
 - пассивные
 - отвлекающие

Отдельно стоит отметить средства контроля (анализа) защищённости и средства управления (оркестрации), которые в явном виде не подпадают под указанные выше критерии классификации.

Система сертификации средств защиты информации

Цель проведения сертификации СрЗИ – это получение независимого подтверждения соответствия СрЗИ требованиям по безопасности информации, которое даёт уверенность потребителям в части применения данного средства для защиты своей информации.

Сертификация – многоступенчатый процесс с множеством участников:

- федеральный орган по сертификации (ФСТЭК России):
 - организует проведение сертификации (система сертификации РОСС RU.01)
 - разрабатывает и устанавливает требования по безопасности информации
 - выпускает сертификаты соответствия
 - ведёт [Государственный реестр сертифицированных СрЗИ](#)
- изготовители СрЗИ: разрабатывают (производят) СрЗИ
- заявители (организации-изготовители или организации, планирующие применять СрЗИ): подают заявление в ФСТЭК России
- организации - испытательные лаборатории:
 - проводят сертификационные испытания
 - оформляют технические заключения и протоколы
- организации - органы по сертификации:
 - оценивают материалы сертификационных испытаний
 - оформляют экспертное заключение о возможности/невозможности выдачи сертификата соответствия

 Зачастую организации и отдельные команды разработчиков самостоятельно занимаются разработкой программных СрЗИ, которые позднее нужно будет сертифицировать. Но организации-изготовители изначально должны иметь лицензию ФСТЭК России на деятельность по разработке и производству средств защиты конфиденциальной информации. Без этого деятельность считается неправомерной, а будущая сертификация будет невозможна.

Порядок проведения сертификации предусматривает:

- подачу заявки на сертификацию в ФСТЭК России
- принятие ФСТЭК России решения о проведении сертификации СрЗИ
- сертификационные испытания СрЗИ в испытательной лаборатории

- оформление органом по сертификации экспертного заключения по результатам сертификации СрЗИ и проекта сертификата соответствия
- выдачу (отказ в выдаче) ФСТЭК России сертификата соответствия
- предоставление дубликата сертификата соответствия (при необходимости)
- маркирование СрЗИ
- внесение изменений в сертифицированное СрЗИ
- переоформление сертификата соответствия
- продление срока действия сертификата соответствия
- приостановление действия сертификата соответствия
- прекращение действия сертификата соответствия

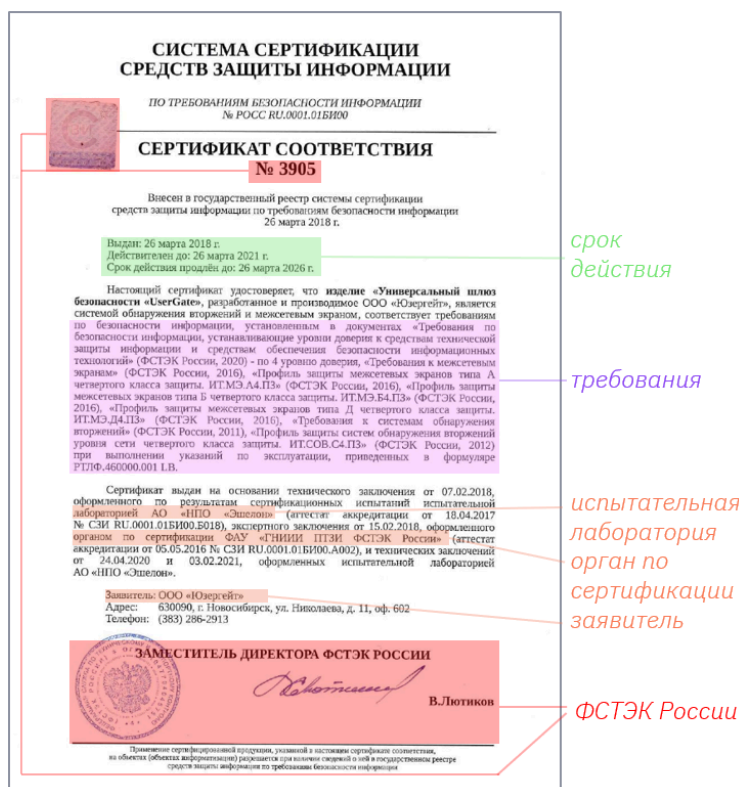
Существует несколько вариантов (схем) сертификации:

- для единичного образца СрЗИ: проведение испытаний образца и проверки организации его технической поддержки (организуется заявителем, планирующим применять СрЗИ, в случае если отсутствуют идентичные серийные уже сертифицированные СрЗИ)
- для партии СрЗИ: проведение испытаний выборки образцов и проверки организации его технической поддержки (организуется заявителем, планирующим применять СрЗИ, в случае если отсутствуют идентичные серийные уже сертифицированные СрЗИ)
- для серийного производства СрЗИ: проведение испытаний выборки образцов и проверки организации его производства и технической поддержки (организуется заявителем, осуществляющим разработку и/или производство СрЗИ)

Срок действия сертификата соответствия не может превышать 5 лет для схемы серийного производства СрЗИ, т.е. требуется пересертификация.

Срок действия сертификата соответствия не устанавливается для единичного образца или партии СрЗИ, т.е. формально является бессрчным, но реально действует, пока на СрЗИ есть техническая поддержка.

Пример сертификата соответствия с указанием его ключевых элементов приведён ниже:



срок
действия

требования

испытательная
лаборатория
орган по
сертификации
заявитель

ФСТЭК России

Содержательная часть действующей системы сертификации РОСС RU.01 построена на базе так называемых Общих критериев (Common Criteria).

Стоит отметить, что, к сожалению, нормативно-правовые и методические документы по линии Общих критериев в РФ не до конца гармонизированы, т.е. существует несколько одновременно действующих документов:

- Руководящие документы Гостехкомиссия России (ныне ФСТЭК России) «Безопасность информационных технологий. Критерии оценки безопасности информационных технологий» (2003 г.), 3 части
- ГОСТ Р ИСО/МЭК 15408 «Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий» (2012 – 2013 гг.), 3 части
- Требования по безопасности информации, устанавливающие уровни доверия к средствам технической защиты информации и средствам обеспечения безопасности информационных технологий, утв. приказом ФСТЭК России от 02.06.2020 N 76 [1]
- ISO/IEC 15408 «Information security, cybersecurity and privacy protection — Evaluation criteria for IT security» (1999 – 2022 гг.), 5 частей

Требования по безопасности информации, устанавливающие уровни доверия [1]:

- являются обязательными требованиями к продукции (работам, услугам), используемой в целях защиты сведений, составляющих государственную тайну или относимых к охраняемой в соответствии с законодательством РФ иной информации ограниченного доступа
- устанавливают уровни, характеризующие безопасность применения средств для обработки и защиты информации: 6 уровней доверия (самый низкий уровень – шестой, самый высокий – первый).

Для защиты конфиденциальной информации оперируют 4 – 6 уровнями доверия:

6 уровень доверия (СрЗИ 6 класса) • ЗОКИИ: 3 категория • ГИС: 3 класс защищённости • ИСПДн: 3 и 4 уровни защищённости ПДн	5 уровень доверия (СрЗИ 5 класса) • ЗОКИИ: 2 категория • ГИС: 2 класс защищённости • ИСПДн: 2 уровень защищённости ПДн	4 уровень доверия (СрЗИ 4 класса) • ЗОКИИ: 1 категория • ГИС: 1 класс защищённости • ИСПДн: 1 уровень защищённости ПДн
--	---	---

Считается, что СрЗИ соответствует заданному уровню доверия, если оно удовлетворяет следующим группам требований:

- к разработке и производству средства
- проведению испытаний средства
- поддержке безопасности средства

Для каждого вида СрЗИ (например, межсетевой экран, средство антивирусной защиты и т.п.) ФСТЭК России утверждается нормативно-правовой акт «Требования по безопасности информации», условно *общие требования*. Для каждого класса (с первого по шестой) и каждого типа СрЗИ (если он вводится: тип А, Б и т.д.) ФСТЭК России утверждаются «Профили защиты», условно *детализированные требования*. А уже для каждого конкретного СрЗИ заявителем разрабатывается «Задание по безопасности», условно *адаптированные детализированные требования*, которое используется при сертификации.

В настоящее время требования по безопасности информации предъявлены ФСТЭК России:

- к системам обнаружения вторжений
- средствам антивирусной защиты
- средствам доверенной загрузки
- средствам контроля съемных машинных носителей информации

- межсетевым экранам
- операционным системам
- средствам обеспечения безопасной дистанционной работы в системах
- средствам контейнеризации
- средствам виртуализации

Если нет утверждённых ФСТЭК России требований по безопасности информации, то заявитель просто указывает уровень доверия и разрабатывает «Технические условия».

Заключение по блоку система сертификации:

- изначально учитывайте необходимость (отсутствие необходимости) сертификации по требованиям безопасности информации разрабатываемого ПО (например, применение в составе государственной информационной системы)
- проверяйте наличие готовых «Требований по безопасности информации» и «Профилей защиты» к соответствующим классам (типам) СрЗИ, изначально учитывайте их положения при разработке
- помните, что в процессе сертификации участвуют несколько сторон, процесс стоит денег и может занимать по времени примерно полгода
- внесение изменений в ПО потребует проведения дополнительных испытаний, т.е. сертификация не является разовым мероприятием

Встроенные и наложенные средства защиты информации

Стоит начать со встроенных СрЗИ, которые зачастую называются механизмами защиты информации.

Любое взаимодействие с информационными системами в 99% случаев начинается с идентификации и аутентификации сторон, чтобы понять, с кем это взаимодействие будет происходить. Как следствие, последующее решение о предоставлении доступа для использования информационных и вычислительных ресурсов, основывается на результатах идентификации и аутентификации.

Идентификация

Процедуру идентификации пользователя (субъекта доступа) согласно ГОСТ Р 58833-2020 [2] можно разделить:

- на первичную: присвоение субъекту (объекту) доступа идентификатора (регистрация)
- вторичную: проверка при доступе существования предъявленного идентификатора

Идентификатор пользователя должен быть уникальным (в противном случае будет коллизия), им может выступать:

- user name
- login ID
- personal identification number (PIN)
- адрес электронной почты (при регистрации на внешних ресурсах)
- устройства идентификации

Идентификатор может назначаться «сверху» или выбираться (создаваться) самостоятельно пользователем в соответствии с установленными правилами. Первичная идентификация должна завершаться регистрацией идентификационной информации и присвоением уникального идентификатора доступа или обоснованным отказом.

Целью вторичной идентификации является опознавание пользователя, запросившего доступ к объекту доступа. При этом должна выполняться проверка существования идентификатора доступа, предъявленного пользователем, в перечне присвоенных идентификаторов. При наличии предъявленного идентификатора доступа в перечне присвоенных идентификаторов процесс вторичной идентификации должен считаться успешно пройденным, в противном случае – будет отказ в переходе к следующему шагу «аутентификации».

Аутентификация

Процедура аутентификации должна позволить подтвердить, что идентифицированный пользователь (субъект доступа) – это именно тот, кем он представляется (чей идентификатор он предъявляет).

Для этого могут применяться различные типы факторов:

- факторы знания (something you know): пользователь должен знать определённую информацию, например:
 - пароль (password)
 - ответ на «секретный» вопрос
- фактор владения (something you have): пользователь должен обладать определённым предметом, содержащим аутентификационную информацию, например:
 - токен (token)
 - «таблетка» (touch memory, iButton)
- Биометрический фактор (something you are) или поведение (something you do): пользователю должен быть свойственен определённый признак (характеристика), информация о котором (которой) используется при аутентификации, например:
 - отпечаток пальца
 - сетчатка или радужная оболочка глаза
 - геометрия лица
 - походка или жест

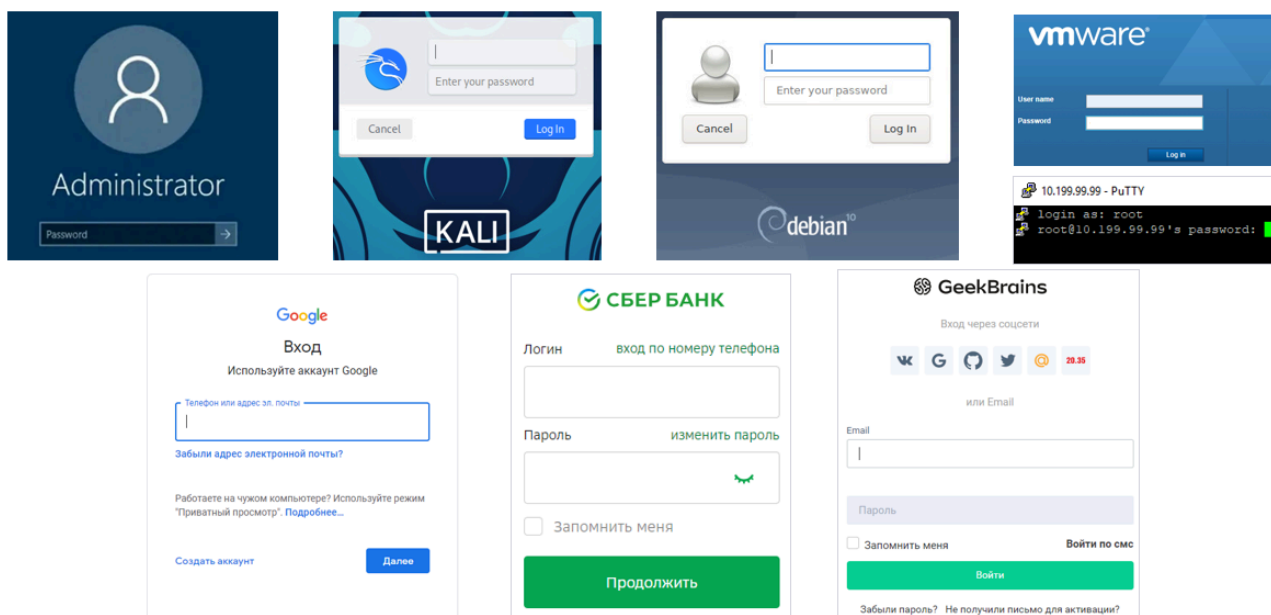
Для аутентификации необходимо использовать один фактор (однофакторная аутентификация) или несколько факторов (многофакторная аутентификация, чаще всего двухфакторная; например: пароль и токен).

 Применение двух паролей или пароля и ответа на «секретный» вопрос не являются двухфакторной аутентификацией, т.к. используются аутентификаторы, относящиеся к одному фактору: «знания».

Когда информационных систем очень много организации стараются применить технологию единой сквозной аутентификации single sign-on (SSO), при использовании которой пользователь переходит из одной системы в другую, не связанную с первой системой, без повторной аутентификации.

Пароли

Стоит отметить, что на практике наибольшее распространение получила аутентификация по паролю:



🔥 «Как ни плохи пароли, люди находят способ сделать их ещё хуже. Если вы попросите их выбрать пароль, он будет паршивый. Если вы принудите их выбрать хороший пароль, они напишут его на карточке и прикрепят к монитору. Если вы попросите поменять его, они сменят его на пароль, которым пользовались месяц назад», Брюс Шнайер.

Ежегодные исследования показывают, что наиболее популярные пароли из года в год фактически одни и те же:

- password
- 123456
- 123456789
- guest
- qwerty
- 111111

Как мы видим, это стандартные последовательности клавиш и часто употребляемые слова, что позволяет атакующему очень быстро подобрать нужный пароль. О популярных парольных атаках мы поговорим чуть позже.

Что можно сделать, чтобы пароль оказался более стойким? Фактически есть три параметра влияющих на стойкость пароля:

- длина: на текущий момент требуется не менее 8 символов

- сложность пароля, которую можно достичь «вбиванием» требований к составу (большие буквы, маленькие буквы, цифры и специальные символы) или использованием мнемонических паролей
- смена пароля: периодическая или, как минимум, при подозрении на компрометацию

Для наглядной демонстрации воспользуйтесь [сервисом от Лаборатории Касперского](#), чтобы проверить стойкость ваших паролей.

В части проверки подозрений на компрометацию (утечку паролей) от ваших аккаунтов или публичных сервисов электронной почты можно воспользоваться сервисами от [2ip](#) и [have i been pwned](#).

Популярные парольные атаки

Уже известная вам матрица MITRE ATT&CK® предусматривает отдельную тактику для получения идентификационных и аутентификационных данных: «[Credential Access](#)».

К наиболее популярным парольным атакам можно отнести:

- угадывание пароля (password guessing): онлайн попытки ввести разные пароли для одного идентификатора (login-a)
- «распыление» пароля (password spraying): онлайн попытки ввести один или несколько распространённых паролей для нескольких идентификаторов (login-ов)
- взлом паролей через его хэш (password cracking):
 - словарные атаки: офлайн перебор хэшей для популярных паролей
 - гибридные атаки: офлайн перебор хэшей для популярных паролей с добавлением/удалением символов
 - brute-force атаки: оффлайн перебор всех возможных вариантов
- перехват паролей, передаваемых в открытом виде
- получение доступа к паролю, хранящемуся в открытом виде

Современные протоколы аутентификации

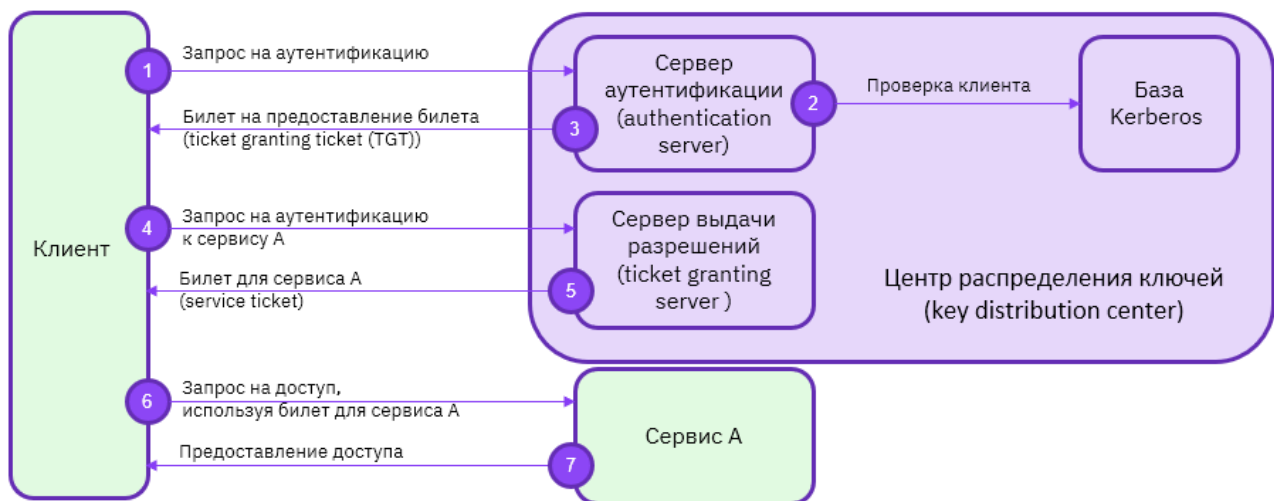
Протоколы аутентификации предусматривают порядок взаимодействия сторон, вовлечённых в процедуру аутентификации.

Условно они могут быть поделены на три группы:

- с предоставлением самого пароля: отправление идентификатора пользователя и пароля в открытом виде, сверка их на стороне получателя со своей «картотекой» идентификаторов и паролей
- с предоставлением хэша-пароля: преобразование пароля с использованием хэш-функции, отправление идентификатора пользователя и хэша пароля, сверка их на стороне получателя со своей «картотекой» идентификаторов и хэшей паролей
- с использованием доверенных серверов аутентификации и асимметричного шифрования

К наиболее популярным современным протоколам аутентификации можно отнести:

- Password Authentication Protocol (PAP): передача идентификатора пользователя и пароля в открытом виде от клиента на сервер, на котором храниться пароль, для их сверки (является самым не безопасным вариантом)
- Challenge Handshake Authentication Protocol (CHAP): используется механизм разовых запросов-ответов (пароль не передаётся, он храниться на сервере (иногда в открытом виде))
- Lightweight Directory Access Protocol (LDAP): используется LDAP-сервер (служба каталогов), хранящий сведения о пользователях, в т.ч. пароли, данный сервер выступает посредником при взаимодействии пользователя с системой/сервисом; есть три варианта взаимодействия:
 - Anonymous Bind: пароль не требуется
 - Simple Password Bind: требуется идентификатор пользователя и пароль в открытом виде
 - Simple Authentication and Security Layer (SASL): требуется идентификатор пользователя и хешированный пароль
- Kerberos: используется выделенный сервер аутентификации и сеансовые билеты (tickets)



- Security Assertion Markup Language (SAML): используется провайдер удостоверений (identity provider), позволяющий получить доступ к нескольким независимым приложениям поставщиков услуг (service provider) в разных доменах путем обмена пользовательской информацией между провайдером удостоверений и поставщиками услуг
- Transport Level Security (TLS): используются цифровые сертификаты, выданные сторонними удостоверяющими центрами (certificate authority) или самоподписанные, для аутентификации клиента и сервера/сервиса
- Open Authorization (OAuth) и OpenID Connect (OIDC): делегирование авторизации для приложений по доступу к данным в другом приложении, основанное на HTTP-запросах



Чтобы проще понять схему работы протокола Kerberos, рассмотрим аналогию с посещением парка аттракционов [3]:

- посетитель (клиент) приходит на вход и показывает охраннику свой паспорт
- охранник проверяет наличие посетителя в базе данных
- охранник выдаёт посетителю суточный билет на посещение парка (TGT)
- посетитель выбирает понравившийся ему аттракцион и идёт в кассу, чтобы получить билет на этот аттракцион
- кассир проверяют суточный билет посетителя и выдают билет на аттракцион (service ticket)
- посетитель идёт на выбранный аттракцион и показывает смотрителю аттракциона, полученный на кассе билет
- смотритель проверяет билет и пропускает посетителя

Дополнительно можно отметить следующие методы, используемые при аутентификации в рамках API-взаимодействия (API authentication methods):

- Basic HTTP Authentication: передача идентификатора пользователя и пароля в открытом виде (base64) в заголовке HTTP-запроса от клиента на сервер
- API Keys: использование уникального ключа (длинной строки символов), которую обычно включают либо в URL запроса, либо в заголовок HTTP-запроса
- OAuth 2.0: редирект HTTP-запроса к сервису авторизации, получение токена доступа (access token) и его дальнейшее использование при взаимодействии с API

Авторизация

На практике используются несколько основных методов (моделей) разграничения прав доступа пользователей к системам и данным, успешно прошедшим процедуры идентификации и аутентификации:

- мандатное разграничение прав доступа (Mandatory Access Control (MAC))
- дискреционное разграничение доступа (Discretionary Access Control (DAC))
- ролевое разграничение прав доступа (Role-Based Access Control (RBAC))



При этом независимо от выбранного метода разграничения прав доступа в рамках предоставления доступа необходимо руководствоваться принципом наименьших привилегий (**principle of least privilege**), т.е. предоставлять минимально возможный уровень привилегий / разрешений.

Мандатное разграничение прав доступа

Первой формальной моделью мандатного доступа является модель, разработанная в корпорации MITRE Дэвидом Беллом и Леонардом ЛаПадулой в начале 70-ых годов прошлого века [4], получившая название «Модель Белла-ЛаПадулы».

Мандатный метод основан на иерархической категоризации объектов и субъектов доступа (пользователей), где каждому объекту и субъекту назначаются некоторые иерархические уровни безопасности, объектам присваиваются метки безопасности (security label), а субъектам уровни допуска. Каждый пользователь имеет доступ к соответствующему уровню.

В основе разграничения прав лежит два принципа:

- нет чтения вверх (no read up)
- нет записи вниз (no write down)



В первой части, фактически, пользователь не имеет права знакомиться с информацией (читать), уровень безопасности которой выше его уровня допуска, чтобы не узнать «лишнего». Во второй части, пользователь не имеет права вносить информацию (писать) своего уровня безопасности в документ с более низким уровнем безопасности, чтобы случайно или намеренно «не слить» более секретную информацию в менее секретную.

У пользователя нет возможности самостоятельно менять свой уровень допуска.

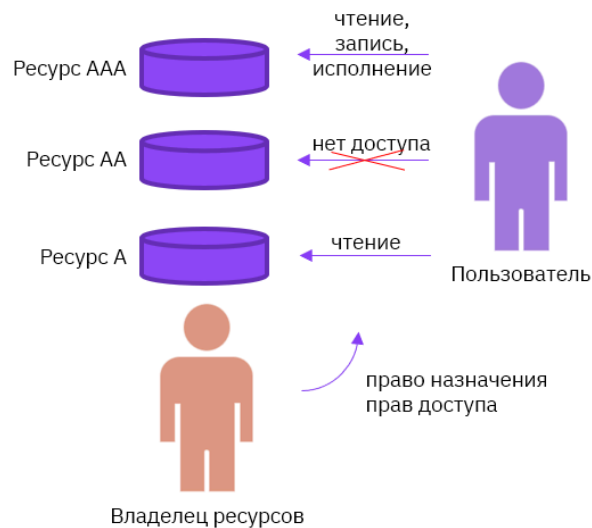
На практике данный метод применяется при защите государственной тайны.

Дискреционное разграничение прав доступа

Модели дискреционного доступа – это самые многочисленные модели разграничения прав доступа, реализованных в большинстве систем и отдельных приложений. Первые работы по данным моделям появились в 60-х годах прошлого века [4].

Дискреционный метод основан на явном сопоставлении прав доступа конкретного субъекта доступа (пользователя) и конкретного объекта (каталог, файл и т.п.). Это сопоставление может быть представлено в форматах:

- матрицы доступа (access control matrix)
- списков доступа (access control list)



Стоит отметить, что право устанавливать (назначать) права доступа изначально принадлежит владельцу того объекта, к которому доступ предоставляется, и даже это право может быть предоставлено отдельным пользователям.

На практике данный метод применяется в операционных системах семейств Microsoft Windows и Linux при разграничении прав доступа к каталогам, файлам и т.п.

Ролевое разграничение прав доступа

Ролевое разграничение прав доступа представляет собой развитие метода дискреционного разграничения прав доступа, при этом права доступа для пользователей группируются (объединяются) с учётом специфики их применения, образуя роли.

Фактически, роль – это набор логически сгруппированных функциональных обязанностей, прав доступа и/или полномочий. Это очень удобно, т.к. новому пользователю достаточно присвоить нужную роль(и), и он автоматически получает все необходимые доступы к системам и данным.

На практике данный метод применяется в операционных системах семейств Microsoft Windows и Linux при разграничении прав доступа к возможностям по администрированию системы, а также в системах управления базами данных (СУБД) и различных приложениях.

Регистрация (учёт) событий безопасности

События, включая события безопасности, регистрируются различным ПО и СрЗИ, т.е. записываются в журнал регистрации событий (журнал аудита событий). Каждое ПО может вести один или несколько журналов регистрации событий.

Условно можно выделить следующие ключевые поля в составе события безопасности:

- дата и время регистрации события безопасности (метка времени)
- идентификатор события безопасности
- содержательная часть события безопасности

Опционально могут присутствовать следующие поля:

- категория события безопасности
- уровень важности (критичности) события безопасности

Стоит отметить, что, к сожалению, в различных системах (отдельных приложениях) события регистрируются по-разному:

- сплошным текстом (plain text)
- текстом с разделителями (CSV и TSV)
- наборами пар «ключ — значение» (JSON и XML)

а также любыми их комбинациями, поэтому на сегодняшний день нет единого стандарта описания событий.

К наиболее популярным категориям событий безопасности, подлежащим регистрации стоит отнести:

- управление учётными записями и аутентификаторами (паролями), особенно привилегированными учётными записями
- вход и попытки входа пользователей, особенно удалённого доступа и попытки входа привилегированных пользователей
- управление журналами регистрации событий, особенно отключение аудита событий или очистка журналов регистрации событий
- сбои в работе СрЗИ, особенно отключение СрЗИ или длительное отсутствие связи с системой управления

Средство антивирусной защиты

Средство антивирусной защиты является ключевым наложенным СрЗИ.

К основным функциям средства антивирусной защиты относятся:

- обнаружение вредоносного ПО:
 - сигнатурный анализ
 - эвристический (вероятностный) анализ
 - поведенческий анализ
- удаление вредоносного ПО
- обработка инфицированных объектов с целью их восстановления
- блокирование определённых операций и/или ПО
- обновление баз данных признаков вредоносного ПО

В дополнение к средствам антивирусной защиты могут применяться сервисы для антивирусного (репутационного) анализа подозрительных файлов, IP-адресов и т.п.:

- самый популярный сервис [VirusTotal](https://www.virustotal.com/), поддерживающий API-запросы
- портал Лаборатории Касперского [Kaspersky Threat Intelligence Portal](https://www.kaspersky.com/threat-intelligence)
- сервис для проверки IP-адресов, IP-подсетей и доменных имён [AbuseIPDB](https://www.abuseipdb.com/)
- портал корпорации IBM [IBM X-Force Exchange](https://xforce.ibmcloud.com/)

Сигнатурный анализ

Суть сигнатурного анализа состоит в выявлении характерных признаков вредоносного ПО (формировании сигнатур) и дальнейшем поиске вредоносного ПО путём сравнения проверяемых файлов со сформированной базой данных признаков вредоносного ПО.

Стоит отметить, что для получения сигнатуры необходимо иметь образец вредоносного ПО. Следовательно, сигнатурный анализ непригоден для защиты от нового (неизвестного) вредоносного ПО. Вирусописатели стараются использовать различные методы, затрудняющие сигнатурный анализ:

- обфускация кода, пермутация и/или «генерация мусора», т.е. всё, что может запутать код и увести его от имеющегося в базе средства антивирусной защиты характерного признака
- упаковка: код вредоносного ПО шифруется (перешифровывается), а расшифровывается только при исполнении

Эвристический анализ

Суть эвристического анализа состоит в том, что решение об отнесении приложения к вредоносному основывается на некоторых предположениях, а не на строгих признаках – сигнатурах.

Эвристический анализ основывается на предположении, что новое вредоносное ПО часто оказываются похожим на какие-либо уже существующее. Средство антивирусной защиты отслеживает особенности работы процессов, места записи исполняемых и временных файлов, используемые ветки реестра операционной системы и т.п. Безусловно, здесь возникают ложные срабатывания, местами даже на другие СрЗИ.

Вирусописатели стараются использовать различные методы, затрудняющие эвристический анализ, в первую очередь, делая вредоносное ПО модульным и «мутируя» его версии.

Поведенческий анализ

Суть поведенческого анализа состоит в отслеживании поведения приложения путём запуска его в песочнице (sandbox). Фактически это развитие метода эвристического анализа.

В песочнице эмулируются различные действия пользователей, в т.ч. перематывается время.

Вирусописатели стараются использовать различные методы, затрудняющие поведенческий анализ, в первую очередь, это «анти песочница», т.е. обнаружение того, что вредоносное ПО оказалось в песочнице и непоявление деструктивных свойств в ней.

Наложенные СрЗИ от несанкционированного доступа

К основным функциям наложенных СрЗИ от НСД относятся:

- двухфакторная (мультифакторная) аутентификация
- доверенная загрузка операционной системы
- мандатное разграничение прав доступа
- контроль целостности отдельных файлов
- расширенный аудит событий безопасности
- гарантированное удаление данных (затирание)

- шифрование данных

Особенности применения наложенных антивирусов и СрЗИ от НСД, которые требуется учитывать:

- совместимость с общесистемным и прикладным ПО
- негативное влияние на производительность хоста
- дополнительная квалификация для администрирования

Заключение по блоку встроенных и наложенных СрЗИ:

- начинайте с использования встроенных средств (механизмов) защиты информации
- идентификация и аутентификация – это первый рубеж в составе любой системы защиты информации
- грамотное разграничение прав доступа (авторизация) в совокупности с принципом минимальных привилегий позволят нейтрализовать большую часть способов реализации угроз
- регистрация событий позволит обнаружить те способы реализации угроз, которые могут быть успешными несмотря на идентификацию, аутентификацию и авторизацию (а такие всегда найдутся)
- среди наложенных СрЗИ – решением по умолчанию является антивирус
- целесообразность применения наложенных СрЗИ от НСД должна определяться моделью угроз после предварительного тестирования на совместимость

Хостовые и сетевые средства защиты информации

На сегодняшний день хостовые и сетевые СрЗИ фактически либо дублируют друг друга, либо дополняют в составе единых систем.

 Персональный межсетевой экран

 Межсетевой экран

 Host IDS

 Network IDS

 Хостовые агенты системы предотвращения утечек данных (DLP)

 Сетевые сенсоры систем предотвращения утечек данных (DLP)

 Endpoint Detection and Response (EDR)

 Network Traffic Analysis (NTA)

Extended Detection and Response (XDR)

Межсетевые экраны

Межсетевой экран (МЭ, Брандмауэр, Firewall (FW), Unified Threat Management (UTM)) является ключевым сетевым СрЗИ. Хотя они бывают и хостовыми (персональными), встроенными в большинство операционных систем семейств Microsoft Windows и Linux.

К основным функциям межсетевого экрана относятся:

- пакетная фильтрация
- сетевая трансляция адресов (Network Address Translation (NAT))
- трансляция портов (Port Address Translation (PAT))
- аутентификация пользователей, клиентов, сессий
- управление бюджетами пользователей
- виртуальные частные сети (Virtual Private Network (VPN))
- посредник транспортного уровня (circuit-level proxy)
- посредник прикладного уровня (application proxy)

Простая фильтрация пакетов – это возможность межсетевого экрана по блокировке пакетов, попадающих на него, по заданному критерию на основе данных, содержащихся в заголовках IP-пакетов, и дополнительных условий.

В качестве данных из заголовков IP-пакетов для фильтрации могут использоваться:

- IP-адрес хоста-источника (source)
- IP-адрес хоста -получателя (destination)
- тип протокола транспортного уровня (TCP или UDP)
- порт источника TCP/UDP
- порт приёмника TCP/UDP
- длина IP-пакета

А в качестве дополнительных условий могут использоваться:

- сетевой интерфейс межсетевого экрана
- направление передачи трафика (исходящий или входящий)
- время

Посредничество транспортного уровня заключается в том, что связь между двумя хостами физически осуществляется через межсетевой экран и реально состоит из двух TCP-соединений.

Посредничество прикладного уровня заключается в том, что связь между двумя хостами физически осуществляется через межсетевой экран и реально состоит из двух соединений прикладного уровня.

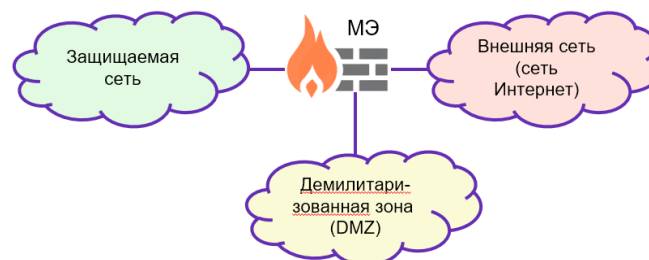
💡 При настройке фильтров/списков доступа (access control list) на межсетевом экране необходимо руководствоваться принципом **«всё, что явно не разрешено – запрещено»**.

Популярные схемы размещения межсетевых экранов:

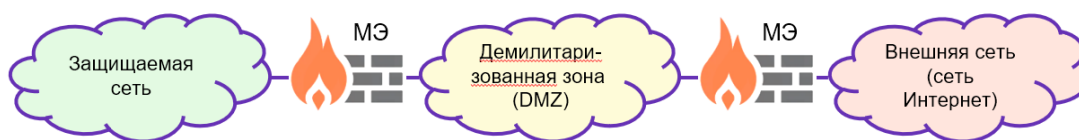
- не эшелонированный периметровый межсетевой экран:



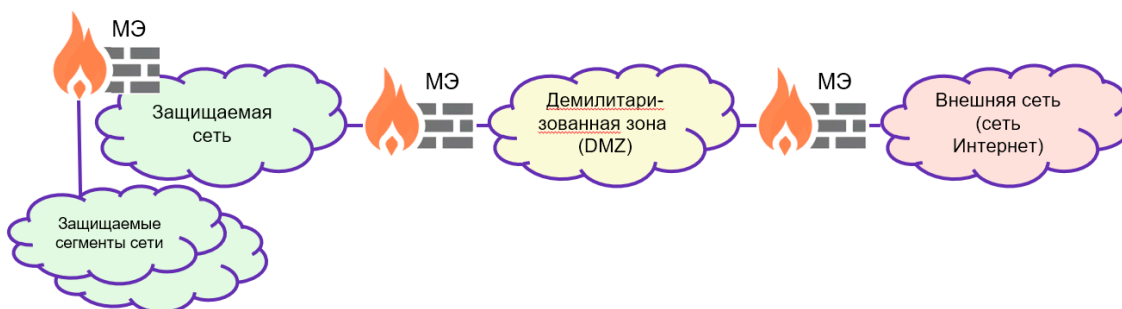
- не эшелонированный периметровый межсетевой экран с выделением демилитаризованной зоны:



- эшелонированные периметровые межсетевые экраны с выделением демилитаризованной зоны:



- эшелонированные периметровые межсетевые экраны с выделением демилитаризованной зоны и внутренней сегментацией на межсетевом экране:



Система обнаружения/предотвращения вторжений

Системы обнаружения/предотвращения вторжений (Intrusion Prevention/Detection Systems (IDS/IPS)) дополняют межсетевые экраны, но, в отличие от них, бывают не только сетевые (network-based) и хостовые (host-based), но и для отдельных приложений (application-based).

К основным функциям систем обнаружения/предотвращения вторжений относятся:

- обнаружение и/или блокирование сетевых атак
- обновление баз данных признаков сетевых атак

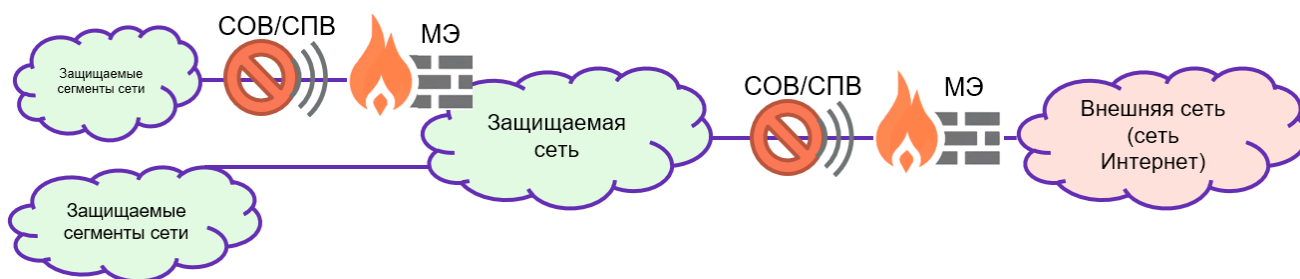
На первый взгляд, кажется очевидным применять именно системы предотвращения вторжений (IPS), на практике в подавляющем большинстве применяются системы обнаружения вторжений (IDS), т.к. существует вероятность блокировки легитимного сетевого трафика.

Популярные схемы размещения систем обнаружения/предотвращения вторжений:

- периметровая система:



- периметровая система и система для критичного сегмента сети:



💡 Обратите внимание, что система обнаружения/предотвращения вторжений располагается за межсетевым экраном, который «срежет» часть нелегитимного сетевого трафика, что позволит не завалить IDS/IPS-систему лишней, ненужной работой. Связано это с тем, что сеть Интернет непрерывно сканируется различными автоматическими системами и атакующими.

Архитектура и схема применения хостовых и/или сетевых СрЗИ определяется конкретными ИТ-условиями и моделью угроз.

Средства управления ИБ

Для любого СрЗИ предусмотрен компонент управления «Сервер/консоль управления», который может быть:

- локальный
- централизованный (оркестратор)

Стоит отметить, что существуют специализированные системы, предназначенные именно для управления:

- данными, связанными с обеспечением ИБ организации (Security Governance, Risk Management and Compliance (SGRC))
- конфигурациями сетевого оборудования и сетевых СрЗИ (Network Security Policy Management (NSPM))

🔥 Данные средства интересны для атакующих как с точки зрения противодействия им (нарушения связи с управляемыми СрЗИ, отказа в обслуживании системы управления и т.п.), так и с точки зрения получения контроля над ними – фактически контроля над ИТ-инфраструктурой.

Интеграции и экосистемы средств защиты информации

Мы рассмотрели несколько различных классов СрЗИ, на практике их применяют в разных количественных комбинациях с учётом конкретных ИТ-условий и модели угроз.

Если внедрять каждое СрЗИ само по себе, то в итоге перед администраторами и ИБ-специалистами встаёт задача по обслуживанию и эксплуатации разрозненных средств, данные в них будут дублироваться, что имеет явные недостатки.

Для этого СрЗИ интегрируют между собой. Условно можно выделить следующие направления интеграции:

- «вертикальные»: интеграция для передачи ИБ-данных, например, событий или оповещений от условно нижестоящих СрЗИ, коллекторов и/или программных агентов
- «горизонтальные»: функциональные интеграции, например, со службой каталогов для идентификации/аутентификации пользователей домена, с NTP-сервисом для синхронизации времени, с сервисом электронной почты для рассылки оповещений и т.п.

Часть крупных производителей СрЗИ развивает тематику интеграций своих решений между собой в рамках экосистемы. Одной из первых организаций предложивших экосистему своих продуктов была американская компания McAfee, изначально «заводящая» все свои решения на единую систему управления - ePolicy Orchestrator (McAfee ePO).

К достоинствам экосистемы СрЗИ можно отнести:

- «бесшовность» интеграций средств между собой
- единый (схожий) интерфейс
- централизованные средства управления (оркестратор)

Но есть и недостатки:

- финансовая и технологическая зависимость от конкретного производителя
- сложности с эшелонированностью

Выводы

- Существуют различные некриптографические средства (механизмы) защиты информации
- «Из коробки» большинство систем (отдельных приложений) предлагают набор базовых встроенных механизмов защиты информации:
 - Идентификация
 - Аутентификация
 - Авторизация
 - Регистрация (учёт) событий безопасности
- Применение любого наложенного СрЗИ требует предварительного тестирования на совместимость
- Приобретение и применение любого наложенного СрЗИ – это не только стоимость лицензий, но и аппаратное, и общесистемное обеспечение для его установки, место для резервных копий, электропитание, обслуживание и администрирование (total cost of ownership)

Дополнительные материалы

1. Книга «Секреты и ложь. Безопасность данных в цифровом мире», Брюс Шнайер, 2003.
2. Книга «Семь безопасных информационных технологий», Александр Баронов и др., 2017 г.
3. Статья «[Зачем нужны сертифицированные средства защиты информации?](#)».
4. Статья «[Об оценке соответствия средств защиты информации сообразно «Общим критериям»](#)», Александр Барабанов и др.
5. Статья «[Классификация средств защиты информации от ФСТЭК и ФСБ России](#)». Александр Веретенников.
6. Статья «[Authentication: Methods, Protocols, and Strategies](#)».
7. Статья «[Полезность экосистемного подхода к кибербезопасности](#)», Григорий Ревенко.

Использованная литература

1. [Требования по безопасности информации, устанавливающие уровни доверия к средствам технической защиты информации и средствам обеспечения](#)

[безопасности информационных технологий](#), утв. приказом ФСТЭК России от 02.06.2020 N 76

2. ГОСТ Р 58833-2020 «[Защита информации. Идентификация и аутентификация. Общие положения](#)».
3. Статья «[Kerberos для специалиста по тестированию на проникновение. Часть 1. Теория](#)».
4. Учебное пособие «Теоретические основы компьютерной безопасности», Н.А. Гайдамакин, 2008 г.